

7.15 audit unit 07b1 — formatters and interpolated intent

1. Identity and frozen scope

Owner: 7.15 firmware rehearsal. Worktree: /private/tmp/kk715-stack07b1, branch release/715-stack-07b1-erc7730-formatters, [firmware draft #865](https://github.com/BitHighlander/keepkey-firmware/pull/865). Target: release/715-stack-07-erc7730-core at 8c654bcd8e1c8936a86aaa625a4ab78900a250e9 (7a). Code predecessor before this report: 75824620923c811e0c1e133879eb6d90ca63bdb6. Python companion: deps/python-keepkey at f813519c7c1163783b0e89b5cbd70536831f5e49, [companion draft #114](https://github.com/BitHighlander/python-keepkey/pull/114). The main-worktree MASTER-AUDIT-TEMPLATE.md SHA256 is 743843a17139a7394325a961b9a38666c8e8af7a0005e0ff52eb94559ec8dbb7. This adjacent PR diff contains firmware code; it is not a receipt-only review.

Phase A adds tokenAmount, addressName, containers and constants. Phase B shows the interpolated intent as numbered text and value parts. Phase C adds native amount, NFT name, date, duration, unit and enum. The firmware rejects definitions it cannot run before the first screen. D groups/iteration and E embedded-call execution are assigned to the following units and are absent from this unit's added source.

2. Git inventory and changed behavior

Immutable inventory range for code and tests: git diff --numstat 8c654bcd8e1c8936a86aaa625a4ab78900a250e9..75824620923c811e0c1e133879eb6d90ca63bdb6. Frozen inventory range including the source report and PDF: git diff --numstat 8c654bcd8e1c8936a86aaa625a4ab78900a250e9..25e9ff8819e91183978a94f549c55b8d85eb82d. The report source and PDF are added after that code predecessor. Counts are net adjacent-diff counts, including tests, documentation and the companion gitlink; they are not a sum of overlapping commit counts. The PR body records the final containing head.

Tracked path	Added	Deleted	Change and evidence
deps/python-keepkey	1	1	Pins the matching compiler mirror and its tests.
docs/release/audit-units/715-07b1-formatters-audit-20260926.md	126	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b1-formatters-audit-20260926.pdf	-	-	Rendered audit evidence from the adjacent source report.
docs/security/HANDOFF-ERC7730-715-FORMATTERS.md	67	2	Records on-screen behavior and fail-closed limits.
include/keepkey/firmware/eip712_stream.h	3	0	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_abi_stream.h	2	0	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_capabilities.h	59	7	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_catalog.h	6	0	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_field.h	60	0	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_format.h	5	5	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_program.h	4	0	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_workflow.h	62	0	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/ethereum.h	4	0	Declares bounded state and the phase's runtime contract.
lib/firmware/CMakeLists.txt	1	0	Builds the new source or native regression suite.
lib/firmware/eip712_stream.c	10	0	Implements the phase's bounded decoding or display rule.
lib/firmware/erc7730_abi_stream.c	8	3	Captures only bounded ABI facts and records overflow.
lib/firmware/erc7730_capabilities.c	162	10	Selects the exact formatter and display capabilities.

lib/firmware/erc7730_catalog.c	79	1	Refuses unexecutable signed programs before review.
lib/firmware/erc7730_field.c	255	0	Formats decoded values with signer provenance visible.
lib/firmware/erc7730_format.c	1	5	Implements the phase's bounded decoding or display rule.
lib/firmware/erc7730_program.c	12	0	Implements the phase's bounded decoding or display rule.
lib/firmware/erc7730_workflow.c	112	7	Keeps replay, validation and UI state in sequence.
lib/firmware/ethereum.c	12	0	Implements the phase's bounded decoding or display rule.
lib/firmware/fsm_msg_ethereum.h	722	88	Shows and confirms the device-decoded review screens.
scripts/emulator/test_stack07_regressions.py	228	10	Exercises signed wire requests and review screens.
unittests/firmware/CMakeLists.txt	1	0	Builds the new source or native regression suite.
unittests/firmware/erc7730_abi_stream.cpp	10	2	Covers accepted neighbors and fail-closed boundaries.
unittests/firmware/erc7730_catalog.cpp	370	19	Covers accepted neighbors and fail-closed boundaries.
unittests/firmware/erc7730_field.cpp	280	0	Covers accepted neighbors and fail-closed boundaries.
unittests/firmware/erc7730_format.cpp	14	10	Covers accepted neighbors and fail-closed boundaries.
unittests/firmware/erc7730_program.cpp	21	0	Covers accepted neighbors and fail-closed boundaries.

Before this unit, the device did not execute these formatter families or show interpolated intent parts from the signed definition. It now decodes the signed calldata or typed-data value, marks signer-supplied text, and keeps the raw fact visible. This matters because a label, native alias or constant from the signer must not masquerade as a device-decoded value. The catalog and field suites exercise the accepted cases and adjacent preload refusals; the Python compiler mirror is tested against the firmware validator.

3. Current-source findings and limits

Finding	Disposition and evidence
D1 numeric signer constants	Non-raw formatter values are refused at preload; native catalog test <code>OnlyARawFieldShowsASignerConstant</code> .
D3 long signer text and unit decimals	Preload bounds text at 64 bytes and decimals at 77; <code>SignerTextAndDecimalsFitTheScreenAtPreload</code> .
D4 Wanchain state and D5 token-table precedence	Native amount ignores stale Wanchain state and the firmware token table beats a signer alias; field tests cover both.
D6/D7 intent identity and long values	Text/value titles are distinct; numbered parts split at line boundaries, with confirmation of every part.
D8 control bytes and oversized raw values	Controls are escaped; too-long calldata raw values show a blind warning and length, while typed-data values point to the full earlier walk. Field, format and ABI capture tests cover the bounds.
D12 root signer path	Empty EIP-712 address path is accepted as the root key, matching signing derivation.
D16 signer-supplied labels	Unit base, threshold and enum marks precede the corresponding value; the raw unit integer is always shown.
Copilot round 2 NUL replay finding	The independent string replay reader rejects NUL; <code>Erc7730ProgramString.RejectsEmbeddedNulBeforeDisplay</code> passes.
Copilot round 3 native alias finding	A signer native alias shows <code>Signer native alias</code> and the exact address before the native-unit amount; max uint256 and Wanchain boundaries pass.

The historical 102-agent report preserved clusters rather than all 42 raw finding rows. The top split receipt maps the surviving groups and records the absent raw manifest explicitly. No historical finding is relabeled as a clean external review. Physical-device confirmation remains a release gate.

4. Verification and artifacts

Check	Exact source or run	Result and limit
Full native firmware	758246209 in a clean Docker run directory	firmware-unit 649/649 passed.

Focused catalog and formatter	758246209	63 catalog/field/format/ABI tests passed; independent NUL test passed.
Host/device mirror	firmware validator built from 758246209, Python f813519	Two targeted compiler/validator cases passed.
Corrected cppcheck	758246209, Ubuntu 24.04 CI flags	Zero findings.
First hosted split run	GitHub Actions 36268229311, head 758246209	In progress when this source report was prepared; final exact-head status belongs in the PR body.
ARM and wire	Same hosted run	Pending final job status when this source report was prepared; no physical device used.

The canonical pre-push script failed on inherited duplicate Osmosis/Solana nanopb options, the absent `scripts/test_generate_test_report.py` in the 7a base, and its own missing `.cppcheck-build` directory. Its other checks passed. The owner approved pushing 7b with that exception recorded. The script is not called passing.

5. Report preflight and review checkpoint

The readable source and generated PDF contain the same inventory. The PDF was opened and checked for legibility. The base SHA, companion pin, code predecessor and final PR head must be reconciled in the PR body after the report commit. `git diff --check` and `clang-format 20` pass. No new Copilot review has been requested on this smaller unit. The three historical #863 reviews found seven issues in total, all repaired and resolved there; that does not constitute a clean review of this exact adjacent diff.